

AVCDL Background Material

Revision

Version 2
5/19/25 7:39 PM

Author

Charles Wilson

Abstract

This document contains background material from the primary references used to create the AVCDL framework.

License

This work was created by Torc Robotics and is licensed under the **Creative Commons Attribution-Share Alike (CC BY-SA-4.0)** License.

<https://creativecommons.org/licenses/by/4.0/legalcode>

Overview

There are three documents that were foundational to the creation of the AVCDL framework. These are:

- NIST SP 800-181 [***National Initiative for Cybersecurity Education (NICE) Cybersecurity Workforce Framework (NCWF)***] [\[1\]](#)
- NIST Secure Software Development Framework (**SSDF**) [\[2\]](#)
- **Microsoft Security Development Lifecycle (SDL)** [\[3\]](#)

The **NCWF** is a collection of cybersecurity roles and their KSAs. These help provide clarity to the expectation of the cybersecurity SME necessary to accomplish each AVCDL phase requirement.

The **SSDF** is a general secure development framework based on best practices. It also provides references for each of these practices.

The Microsoft SDL (**MSSDL**) is a classic treatment of the problem of applying cybersecurity to the software development lifecycle. Although not designed for safety-critical, cyber-physical systems, it serves as a template for how cybersecurity can overlay standard development lifecycles.

The key aspects of each of these sources will now be addressed in turn.

NCWF Roles

Note: This material is extracted from the NIST NCWF documentation.
It is included here for reference only.

NIST SP 800-181 [*National Initiative for Cybersecurity Education (NICE) Cybersecurity Workforce Framework (NCWF)*] provides an exhaustive breakdown of cybersecurity roles and their associated tasks.

The following NCWF roles have been identified as necessary in support of implementation of **AVCDL**:

- [Cyber Defense Forensics Analyst](#)
- [Cyber Defense Incident Responder](#)
- [Cyber Instructor](#)
- [Information Systems Security Developer](#)
- [Partner Integration Planner](#)
- [Secure Software Assessor](#)
- [Security Architect](#)
- [Software Developer](#)
- [Systems Requirements Planner](#)
- [Systems Security Analyst](#)
- [Vulnerability Assessment Analyst](#)

Note: There will be tasks and abilities called out for roles in NCWF which are not leveraged. Additionally, there will be areas where there is not a 1-to-1 mapping.

Cyber Defense Forensics Analyst (IN-FOR-002)

Analyzes digital evidence and investigates computer security incidents to derive useful information in support of system/network vulnerability mitigation.

ID	Task
T0027	Conduct analysis of log files, evidence, and other information to determine best methods for identifying the perpetrator(s) of a network intrusion.
T0036	Confirm what is known about an intrusion and discover new information, if possible, after identifying intrusion via dynamic analysis.
T0048	Create a forensically sound duplicate of the evidence (i.e., forensic image) that ensures the original evidence is not unintentionally modified, to use for data recovery and analysis processes. This includes, but is not limited to, hard drives, floppy diskettes, CDs, PDAs, mobile phones, GPS, and all tape formats.
T0049	Decrypt seized data using technical means.
T0075	Provide technical summary of findings in accordance with established reporting procedures.
T0087	Ensure that chain of custody is followed for all digital media acquired in accordance with the Federal Rules of Evidence.
T0103	Examine recovered data for information of relevance to the issue at hand.
T0113	Identify digital evidence for examination and analysis in such a way as to avoid unintentional alteration.
T0165	Perform dynamic analysis to boot an 'image' of a drive (without necessarily having the original drive) to see the intrusion as the user may have seen it, in a native environment.
T0167	Perform file signature analysis.
T0168	Perform hash comparison against established database.
T0172	Perform real-time forensic analysis (e.g., using Helix in conjunction with LiveView).
T0173	Perform timeline analysis.
T0175	Perform real-time cyber defense incident handling (e.g., forensic collections, intrusion correlation and tracking, threat analysis, and direct system remediation) tasks to support deployable Incident Response Teams (IRTs).
T0179	Perform static media analysis.
T0182	Perform tier 1, 2, and 3 malware analysis.
T0190	Prepare digital media for imaging by ensuring data integrity (e.g., write blockers in accordance with standard operating procedures).
T0212	Provide technical assistance on digital evidence matters to appropriate personnel.
T0216	Recognize and accurately report forensic artifacts indicative of a particular operating system.

AVCDL Background Material

- T0238 Extract data using data carving techniques (e.g., Forensic Tool Kit [FTK], Foremost).
- T0240 Capture and analyze network traffic associated with malicious activities using network monitoring tools.
- T0241 Use specialized equipment and techniques to catalog, document, extract, collect, package, and preserve digital evidence.
- T0253 Conduct cursory binary analysis.
- T0279 Serve as technical expert and liaison to law enforcement personnel and explain incident details as required.
- T0285 Perform virus scanning on digital media.
- T0286 Perform file system forensic analysis.
- T0287 Perform static analysis to mount an “image” of a drive (without necessarily having the original drive).
- T0288 Perform static malware analysis.
- T0289 Utilize deployable forensics toolkit to support operations as necessary.
- T0312 Coordinate with intelligence analysts to correlate threat assessment data.
- T0396 Process image with appropriate tools depending on analyst's goals.
- T0397 Perform Windows registry analysis.
- T0398 Perform file and registry monitoring on the running system after identifying intrusion via dynamic analysis.
- T0399 Enter media information into tracking database (e.g., Product Tracker Tool) for digital media that has been acquired.
- T0400 Correlate incident data and perform cyber defense reporting.
- T0401 Maintain deployable cyber defense toolkit (e.g., specialized cyber defense software/hardware) to support Incident Response Team mission.
- T0432 Collect and analyze intrusion artifacts (e.g., source code, malware, and system configuration) and use discovered data to enable mitigation of potential cyber defense incidents within the enterprise.
- T0532 Review forensic images and other data sources (e.g., volatile data) for recovery of potentially relevant information.
- T0546 Write and publish cyber defense recommendations, reports, and white papers on incident findings to appropriate constituencies.

Cyber Defense Incident Responder (PR-CIR-001)

Investigates, analyzes, and responds to cyber incidents within the network environment or enclave.

ID	Task
T0041	Coordinate and provide expert technical support to enterprise-wide cyber defense technicians to resolve cyber defense incidents.
T0047	Correlate incident data to identify specific vulnerabilities and make recommendations that enable expeditious remediation.
T0161	Perform analysis of log files from a variety of sources (e.g., individual host logs, network traffic logs, firewall logs, and intrusion detection system [IDS] logs) to identify possible threats to network security.
T0163	Perform cyber defense incident triage, to include determining scope, urgency, and potential impact, identifying the specific vulnerability, and making recommendations that enable expeditious remediation.
T0164	Perform cyber defense trend analysis and reporting.
T0170	Perform initial, forensically sound collection of images and inspect to discern possible mitigation/remediation on enterprise systems.
T0175	Perform real-time cyber defense incident handling (e.g., forensic collections, intrusion correlation and tracking, threat analysis, and direct system remediation) tasks to support deployable Incident Response Teams (IRTs).
T0214	Receive and analyze network alerts from various sources within the enterprise and determine possible causes of such alerts.
T0233	Track and document cyber defense incidents from initial detection through final resolution.
T0246	Write and publish cyber defense techniques, guidance, and reports on incident findings to appropriate constituencies.
T0262	Employ approved defense-in-depth principles and practices (e.g., defense-in-multiple places, layered defenses, security robustness).
T0278	Collect intrusion artifacts (e.g., source code, malware, Trojans) and use discovered data to enable mitigation of potential cyber defense incidents within the enterprise.
T0279	Serve as technical expert and liaison to law enforcement personnel and explain incident details as required.
T0312	Coordinate with intelligence analysts to correlate threat assessment data.
T0395	Write and publish after action reviews.
T0503	Monitor external data sources (e.g., cyber defense vendor sites, Computer Emergency Response Teams, Security Focus) to maintain currency of cyber defense threat condition and determine which security issues may have an impact on the enterprise.
T0510	Coordinate incident response functions.

Cyber Instructor (OV-TEA-002)

Develops and conducts training or education of personnel within cyber domain.

ID	Task
T0030	Conduct interactive training exercises to create an effective learning environment.
T0073	Develop new or identify existing awareness and training materials that are appropriate for intended audiences.
T0101	Evaluate the effectiveness and comprehensiveness of existing training programs.
T0224	Review training documentation (e.g., Course Content Documents [CCD], lesson plans, student texts, examinations, Schedules of Instruction [SOI], and course descriptions).
T0230	Support the design and execution of exercise scenarios.
T0247	Write instructional materials (e.g., standard operating procedures, production manual) to provide detailed guidance to relevant portion of the workforce.
T0316	Develop or assist in the development of computer-based training modules or classes.
T0317	Develop or assist in the development of course assignments.
T0318	Develop or assist in the development of course evaluations.
T0319	Develop or assist in the development of grading and proficiency standards.
T0320	Assist in the development of individual/collective development, training, and/or remediation plans.
T0321	Develop or assist in the development of learning objectives and goals.
T0322	Develop or assist in the development of on-the-job training materials or programs.
T0323	Develop or assist in the development of written tests for measuring and assessing learner proficiency.
T0352	Conduct learning needs assessments and identify requirements.
T0365	Develop or assist in the development of training policies and protocols for cyber training.
T0367	Develop the goals and objectives for cyber curriculum.
T0381	Present technical information to technical and nontechnical audiences.
T0382	Present data in creative formats.
T0395	Write and publish after action reviews.
T0443	Deliver training courses tailored to the audience and physical/virtual environments.
T0444	Apply concepts, procedures, software, equipment, and/or technology applications to students.
T0450	Design training curriculum and course content based on requirements.
T0451	Participate in development of training curriculum and course content.
T0467	Ensure that training meets the goals and objectives for cybersecurity training, education, or awareness.

AVCDL Background Material

- T0519 Plan and coordinate the delivery of classroom techniques and formats (e.g., lectures, demonstrations, interactive exercises, multimedia presentations) for the most effective learning environment.
- T0520 Plan non-classroom educational techniques and formats (e.g., video courses, mentoring, web-based courses).
- T0535 Recommend revisions to curriculum and course content based on feedback from previous training sessions.
- T0536 Serve as an internal consultant and advisor in own area of expertise (e.g., technical, copyright, print media, electronic media).
- T0926 Develop or assist with the development of privacy training materials and other communications to increase employee understanding of company privacy policies, data handling practices and procedures and legal obligations.

Information Systems Security Developer (SP-SYS-001)

Designs, develops, tests, and evaluates information system security throughout the systems development life cycle.

ID	Task
T0012	Analyze design constraints, analyze trade-offs and detailed system and security design, and consider life cycle support
T0015	Apply security policies to applications that interface with one another, such as Business-to-Business (B2B) applications
T0018	Assess the effectiveness of cybersecurity measures utilized by system(s)
T0019	Assess threats to and vulnerabilities of computer system(s) to develop a security risk profile
T0021	Build, test, and modify product prototypes using working models or theoretical models
T0032	Conduct Privacy Impact Assessments (PIAs) of the application's security design for the appropriate security controls, which protect the confidentiality and integrity of Personally Identifiable Information (PII)
T0053	Design and develop cybersecurity or cybersecurity-enabled products.
T0055	Design hardware, operating systems, and software applications to adequately address cybersecurity requirements
T0056	Design or integrate appropriate data backup capabilities into overall system designs, and ensure that appropriate technical and procedural processes exist for secure system backups and protected storage of backup data
T0061	Develop and direct system testing and validation procedures and documentation
T0069	Develop detailed security design documentation for component and interface specifications to support system design and development
T0070	Develop Disaster Recovery and Continuity of Operations plans for systems under development and ensure testing prior to systems entering a production environment
T0076	Develop risk mitigation strategies to resolve vulnerabilities and recommend security changes to system or system components as needed
T0078	Develop specific cybersecurity countermeasures and risk mitigation strategies for systems and/or applications
T0105	Identify components or elements, allocate security functions to those elements, and describe the relationships between the elements
T0107	Identify and direct the remediation of technical problems encountered during testing and implementation of new systems (e.g., identify and find workarounds for communication protocols that are not interoperable)

- T0109 Identify and prioritize essential system functions or sub-systems required to support essential capabilities or business functions for restoration or recovery after a system failure or during a system recovery event based on overall system requirements for continuity and availability
- T0119 Identify, assess, and recommend cybersecurity or cybersecurity-enabled products for use within a system and ensure that recommended products are in compliance with organization's evaluation and validation requirements
- T0122 Implement security designs for new or existing system(s)
- T0124 Incorporate cybersecurity vulnerability solutions into system designs (e.g., Cybersecurity Vulnerability Alerts)
- T0181 Perform risk analysis (e.g., threat, vulnerability, and probability of occurrence) whenever an application or system undergoes a major change
- T0201 Provide guidelines for implementing developed systems to customers or installation teams
- T0205 Provide input to the Risk Management Framework process activities and related documentation (e.g., system life-cycle support plans, concept of operations, operational procedures, and maintenance training materials).
- T0228 Store, retrieve, and manipulate data for analysis of system capabilities and requirements
- T0231 Provide support to security/certification test and evaluation activities
- T0242 Utilize models and simulations to analyze or predict system performance under different operating conditions
- T0269 Design and develop key management functions (as related to cybersecurity)
- T0270 Analyze user needs and requirements to plan and conduct system security development
- T0271 Develop cybersecurity designs to meet specific operational needs and environmental factors (e.g., access controls, automated applications, networked operations, high integrity and availability requirements, multilevel security/processing of multiple classification levels, and processing Sensitive Compartmented Information)
- T0272 Ensure that security design and cybersecurity development activities are properly documented (providing a functional description of security implementation) and updated as necessary
- T0304 Implement and integrate system development life cycle (SDLC) methodologies (e.g., IBM Rational Unified Process) into development environment.
- T0326 Employ configuration management processes
- T0359 Design, implement, test, and evaluate secure interfaces between information systems, physical systems, and/or embedded technologies
- T0446 Design, develop, integrate, and update system security measures that provide confidentiality, integrity, availability, authentication, and non-repudiation

AVCDL Background Material

- T0449 Design to security requirements to ensure requirements are met for all systems and/or applications
- T0466 Develop mitigation strategies to address cost, schedule, performance, and security risks
- T0509 Perform an information security risk assessment
- T0518 Perform security reviews and identify security gaps in architecture.
- T0527 Provide input to implementation plans and standard operating procedures as they relate to information systems security
- T0541 Trace system requirements to design components and perform gap analysis.
- T0544 Verify stability, interoperability, portability, and/or scalability of system architecture

Partner Integration Planner (CO-OPL-003)

Works to advance cooperation across organizational or national borders between cyber operations partners. Aids the integration of partner cyber teams by providing guidance, resources, and collaboration to develop best practices and facilitate organizational support for achieving objectives in integrated cyber actions.

ID	Task
T0571	Apply expertise in policy and processes to facilitate the development, negotiation, and internal staffing of plans and/or memorandums of agreement.
T0581	Assist and advise interagency partners in identifying and developing best practices for facilitating operational support to achievement of organization objectives.
T0582	Provide expertise to course of action development.
T0601	Collaborate with other team members or partner organizations to develop a diverse program of information materials (e.g., web pages, briefings, print materials).
T0627	Contribute to crisis action planning for cyber operations.
T0629	Contribute to the development, staffing, and coordination of cyber operations policies, performance standards, plans and approval packages with appropriate internal and/or external decision makers.
T0635	Coordinate with intelligence and cyber defense partners to obtain relevant essential information.
T0665	Develop or participate in the development of standards for providing, requesting, and/or obtaining support from external partners to synchronize cyber operations.
T0666	Develop or shape international cyber engagement strategies, policies, and activities to meet organization objectives.
T0669	Develop strategy and processes for partner planning, operations, and capability development.
T0670	Develop, implement, and recommend changes to appropriate planning procedures and policies.
T0671	Develop, maintain, and assess cyber cooperation security agreements with external partners.
T0699	Facilitate interactions between internal and external partner decision makers to synchronize and integrate courses of action in support of objectives.
T0700	Facilitate the sharing of 'best practices' and 'lessons learned' throughout the cyber operations community.
T0712	Identify and manage security cooperation priorities with external partners.
T0729	Inform external partners of the potential effects of new or revised policy and guidance on cyber operations partnering activities.
T0732	Integrate cyber planning/targeting efforts with other organizations.

AVCDL Background Material

- T0739 Maintain relationships with internal and external partners involved in cyber planning or related areas.
- T0747 Monitor and evaluate integrated cyber operations to identify opportunities to meet organization objectives.
- T0759 Contribute to the review and refinement of policy, to include assessments of the consequences of endorsing or not endorsing such policy.
- T0760 Provide subject matter expertise to planning teams, coordination groups, and task forces as necessary.
- T0763 Conduct long-range, strategic planning efforts with internal and external partners in cyber activities.
- T0764 Provide subject matter expertise to planning efforts with internal and external cyber operations partners.
- T0766 Propose policy which governs interactions with external coordination groups.
- T0772 Prepare for and provide subject matter expertise to exercises.
- T0784 Provide cyber focused guidance and advice on intelligence support plan inputs.
- T0787 Provide input for the development and refinement of the cyber operations objectives, priorities, strategies, plans, and programs.
- T0795 Provide planning support between internal and external partners.
- T0817 Serve as a conduit of information from partner teams by identifying subject matter experts who can assist in the investigation of complex or unusual situations.
- T0818 Serve as a liaison with external partners.
- T0823 Submit or respond to requests for deconfliction of cyber operations.
- T0825 Synchronize cyber international engagement activities and associated resource requirements as appropriate.
- T0826 Synchronize cyber portions of security cooperation plans.
- T0836 Document lessons learned that convey the results of events and/or exercises.

Secure Software Assessor (SP-DEV-002)

Analyzes the security of new or existing computer applications, software, or specialized utility programs and provides actionable results.

ID	Task
T0013	Apply coding and testing standards, apply security testing tools including “fuzzing” static-analysis code scanning tools, and conduct code reviews.
T0014	Apply secure code documentation.
T0022	Capture security controls used during the requirements phase to integrate security within the process, to identify key security objectives, and to maximize software security while minimizing disruption to plans and schedules.
T0038	Develop threat model based on customer interviews and requirements.
T0040	Consult with engineering staff to evaluate interface between hardware and software.
T0100	Evaluate factors such as reporting formats required, cost constraints, and need for security restrictions to determine hardware configuration.
T0111	Identify basic common coding flaws at a high level.
T0117	Identify security implications and apply methodologies within centralized and decentralized environments across the enterprise’s computer systems in software development.
T0118	Identify security issues around steady state operation and management of software and incorporate security measures that must be taken when a product reaches its end of life.
T0171	Perform integrated quality assurance testing for security functionality and resiliency attack.
T0181	Perform risk analysis (e.g., threat, vulnerability, and probability of occurrence) whenever an application or system undergoes a major change.
T0217	Address security implications in the software acceptance phase including completion criteria, risk acceptance and documentation, common criteria, and methods of independent testing.
T0228	Store, retrieve, and manipulate data for analysis of system capabilities and requirements.
T0236	Translate security requirements into application design elements including documenting the elements of the software attack surfaces, conducting threat modeling, and defining any specific security criteria.
T0266	Perform penetration testing as required for new or updated applications.
T0311	Consult with customers about software system design and maintenance.
T0324	Direct software programming and development of documentation.
T0337	Supervise and assign work to programmers, designers, technologists and technicians, and other engineering and scientific personnel.

AVCDL Background Material

- T0424 Analyze and provide information to stakeholders that will support the development of security application or modification of an existing security application.
- T0428 Analyze security needs and software requirements to determine feasibility of design within time and cost constraints and security mandates.
- T0436 Conduct trial runs of programs and software applications to ensure that the desired information is produced, and instructions and security levels are correct.
- T0456 Develop secure software testing and validation procedures.
- T0457 Develop system testing and validation procedures, programming, and documentation.
- T0516 Perform secure program testing, review, and/or assessment to identify potential flaws in codes and mitigate vulnerabilities.
- T0554 Determine and document software patches or the extent of releases that would leave software vulnerable.

Security Architect (SP-ARC-002)

Ensures that the stakeholder security requirements necessary to protect the organization's mission and business processes are adequately addressed in all aspects of enterprise architecture including reference models, segment and solution architectures, and the resulting systems supporting those missions and business processes.

ID	Task
T0050	Define and prioritize essential system capabilities or business functions required for partial or full system restoration after a catastrophic failure event.
T0051	Define appropriate levels of system availability based on critical system functions and ensure that system requirements identify appropriate disaster recovery and continuity of operations requirements to include any appropriate fail-over/alternate site requirements, backup requirements, and material supportability requirements for system recover/restoration.
T0071	Develop/integrate cybersecurity designs for systems and networks with multilevel security requirements or requirements for the processing of multiple classification levels of data primarily applicable to government organizations (e.g., UNCLASSIFIED, SECRET, and TOP SECRET).
T0082	Document and address organization's information security, cybersecurity architecture, and systems security engineering requirements throughout the acquisition life cycle.
T0084	Employ secure configuration management processes.
T0090	Ensure that acquired or developed system(s) and architecture(s) are consistent with organization's cybersecurity architecture guidelines.
T0108	Identify and prioritize critical business functions in collaboration with organizational stakeholders.
T0177	Perform security reviews, identify gaps in security architecture, and develop a security risk management plan.
T0196	Provide advice on project costs, design concepts, or design changes.
T0203	Provide input on security requirements to be included in statements of work and other appropriate procurement documents.
T0205	Provide input to the Risk Management Framework process activities and related documentation (e.g., system life-cycle support plans, concept of operations, operational procedures, and maintenance training materials).
T0268	Define and document how the implementation of a new system or new interfaces between systems impacts the security posture of the current environment.
T0307	Analyze candidate architectures, allocate security services, and select security mechanisms.
T0314	Develop a system security context, a preliminary system security Concept of Operations (CONOPS) and define baseline system security requirements in accordance with applicable cybersecurity requirements.

AVCDL Background Material

- T0328 Evaluate security architectures and designs to determine the adequacy of security design and architecture proposed or provided in response to requirements contained in acquisition documents.
- T0338 Write detailed functional specifications that document the architecture development process.
- T0427 Analyze user needs and requirements to plan architecture.
- T0448 Develop enterprise architecture or system components required to meet user needs.
- T0473 Document and update as necessary all definition and architecture activities.
- T0484 Determine the protection needs (i.e., security controls) for the information system(s) and network(s) and document appropriately.
- T0542 Translate proposed capabilities into technical requirements.
- T0556 Assess and design security management functions as related to cyberspace.

Software Developer (SP-DEV-001)

Develops, creates, maintains, and writes/codes new (or modifies existing) computer applications, software, or specialized utility programs.

ID	Task
T0009	Analyze information to determine, recommend, and plan the development of a new application or modification of an existing application.
T0011	Analyze user needs and software requirements to determine feasibility of design within time and cost constraints.
T0013	Apply coding and testing standards, apply security testing tools including “fuzzing” static-analysis code scanning tools, and conduct code reviews.
T0014	Apply secure code documentation.
T0022	Capture security controls used during the requirements phase to integrate security within the process, to identify key security objectives, and to maximize software security while minimizing disruption to plans and schedules.
T0026	Compile and write documentation of program development and subsequent revisions, inserting comments in the coded instructions so others can understand the program.
T0034	Confer with systems analysts, engineers, programmers, and others to design application and to obtain information on project limitations and capabilities, performance requirements, and interfaces.
T0040	Consult with engineering staff to evaluate interface between hardware and software.
T0046	Correct errors by making appropriate changes and rechecking the program to ensure that desired results are produced.
T0057	Design, develop, and modify software systems, using scientific analysis and mathematical models to predict and measure outcome and consequences of design.
T0077	Develop secure code and error handling.
T0100	Evaluate factors such as reporting formats required, cost constraints, and need for security restrictions to determine hardware configuration.
T0111	Identify basic common coding flaws at a high level.
T0117	Identify security implications and apply methodologies within centralized and decentralized environments across the enterprise’s computer systems in software development.
T0118	Identify security issues around steady state operation and management of software and incorporate security measures that must be taken when a product reaches its end of life.
T0171	Perform integrated quality assurance testing for security functionality and resiliency attack.
T0176	Perform secure programming and identify potential flaws in codes to mitigate vulnerabilities.

- T0181 Perform risk analysis (e.g., threat, vulnerability, and probability of occurrence) whenever an application or system undergoes a major change.
- T0189 Prepare detailed workflow charts and diagrams that describe input, output, and logical operation, and convert them into a series of instructions coded in a computer language.
- T0217 Address security implications in the software acceptance phase including completion criteria, risk acceptance and documentation, common criteria, and methods of independent testing.
- T0228 Store, retrieve, and manipulate data for analysis of system capabilities and requirements.
- T0236 Translate security requirements into application design elements including documenting the elements of the software attack surfaces, conducting threat modeling, and defining any specific security criteria.
- T0267 Design countermeasures and mitigations against potential exploitations of programming language weaknesses and vulnerabilities in system and elements.
- T0303 Identify and leverage the enterprise-wide version control system while designing and developing secure applications.
- T0311 Consult with customers about software system design and maintenance.
- T0324 Direct software programming and development of documentation.
- T0337 Supervise and assign work to programmers, designers, technologists and technicians, and other engineering and scientific personnel.
- T0416 Enable applications with public keying by leveraging existing public key infrastructure (PKI) libraries and incorporating certificate management and encryption functionalities when appropriate.
- T0417 Identify and leverage the enterprise-wide security services while designing and developing secure applications (e.g., Enterprise PKI, Federated Identity server, Enterprise Antivirus solution) when appropriate.
- T0436 Conduct trial runs of programs and software applications to ensure that the desired information is produced, and instructions and security levels are correct.
- T0455 Develop software system testing and validation procedures, programming, and documentation.
- T0500 Modify and maintain existing software to correct errors, to adapt it to new hardware, or to upgrade interfaces and improve performance.
- T0553 Apply cybersecurity functions (e.g., encryption, access control, and identity management) to reduce exploitation opportunities.
- T0554 Determine and document software patches or the extent of releases that would leave software vulnerable.

Systems Requirements Planner (SP-SRP-001)

Consults with customers to evaluate functional requirements and translate functional requirements into technical solutions.

ID	Task
T0033	Conduct risk analysis, feasibility study, and/or trade-off analysis to develop, document, and refine functional requirements and specifications.
T0039	Consult with customers to evaluate functional requirements.
T0045	Coordinate with systems architects and developers, as needed, to provide oversight in the development of design solutions.
T0052	Define project scope and objectives based on customer requirements.
T0062	Develop and document requirements, capabilities, and constraints for design procedures and processes.
T0127	Integrate and align information security and/or cybersecurity policies to ensure that system analysis meets security requirements.
T0156	Oversee and make recommendations regarding configuration management.
T0174	Perform needs analysis to determine opportunities for new and improved business process solutions.
T0191	Prepare use cases to justify the need for specific information technology (IT) solutions.
T0235	Translate functional requirements into technical solutions.
T0273	Develop and document supply chain risks for critical system elements, as appropriate.
T0300	Develop and document User Experience (UX) requirements including information architecture and user interface requirements.
T0313	Design and document quality standards.
T0325	Document a system's purpose and preliminary system security concept of operations.
T0334	Ensure that all systems components can be integrated and aligned (e.g., procedures, databases, policies, software, and hardware).
T0454	Define baseline security requirements in accordance with applicable guidelines.
T0463	Develop cost estimates for new or modified system(s).
T0497	Manage the information technology (IT) planning process to ensure that developed solutions meet customer requirements.

Systems Security Analyst (OM-ANA-001)

Responsible for the analysis and development of the integration, testing, operations, and maintenance of systems security.

ID	Task
T0015	Apply security policies to applications that interface with one another, such as Business-to-Business (B2B) applications.
T0016	Apply security policies to meet security objectives of the system.
T0017	Apply service-oriented security architecture principles to meet organization's confidentiality, integrity, and availability requirements.
T0085	Ensure all systems security operations and maintenance activities are properly documented and updated as necessary.
T0086	Ensure that the application of security patches for commercial products integrated into system design meet the timelines dictated by the management authority for the intended operational environment.
T0088	Ensure that cybersecurity-enabled products or other compensating security control technologies reduce identified risk to an acceptable level.
T0123	Implement specific cybersecurity countermeasures for systems and/or applications.
T0128	Integrate automated capabilities for updating or patching system software where practical and develop processes and procedures for manual updating and patching of system software based on current and projected patch timeline requirements for the operational environment of the system.
T0169	Perform cybersecurity testing of developed applications and/or systems.
T0177	Perform security reviews, identify gaps in security architecture, and develop a security risk management plan.
T0187	Plan and recommend modifications or adjustments based on exercise results or system environment.
T0194	Properly document all systems security implementation, operations, and maintenance activities and update as necessary.
T0202	Provide cybersecurity guidance to leadership.
T0205	Provide input to the Risk Management Framework process activities and related documentation (e.g., system life-cycle support plans, concept of operations, operational procedures, and maintenance training materials).
T0243	Verify and update security documentation reflecting the application/system security design features.
T0309	Assess the effectiveness of security controls.
T0344	Assess all the configuration management (change configuration/release management) processes.

- T0462 Develop procedures and test fail-over for system operations transfer to an alternate site based on system availability requirements.
- T0469 Analyze and report organizational security posture trends.
- T0470 Analyze and report system security posture trends.
- T0475 Assess adequate access controls based on principles of least privilege and need-to-know.
- T0477 Ensure the execution of disaster recovery and continuity of operations.
- T0485 Implement security measures to resolve vulnerabilities, mitigate risks, and recommend security changes to system or system components as needed.
- T0489 Implement system security measures in accordance with established procedures to ensure confidentiality, integrity, availability, authentication, and non-repudiation.
- T0492 Ensure the integration and implementation of Cross-Domain Solutions (CDS) in a secure environment.
- T0499 Mitigate/correct security deficiencies identified during security/certification testing and/or recommend risk acceptance for the appropriate senior leader or authorized representative.
- T0504 Assess and monitor cybersecurity related to system implementation and testing practices.
- T0508 Verify minimum security requirements are in place for all applications.
- T0526 Provides cybersecurity recommendations to leadership based on significant threats and vulnerabilities.
- T0545 Work with stakeholders to resolve computer security incidents and vulnerability compliance.
- T0548 Provide advice and input for Disaster Recovery, Contingency, and Continuity of Operations Plans.

Vulnerability Assessment Analyst (PR-VAM-001)

Performs assessments of systems and networks within the NE or enclave and identifies where those systems/networks deviate from acceptable configurations, enclave policy, or local policy. Measures effectiveness of defense-in-depth architecture against known vulnerabilities.

ID	Task
T0010	Analyze organization's cyber defense policies and configurations and evaluate compliance with regulations and organizational directives.
T0028	Conduct and/or support authorized penetration testing on enterprise network assets.
T0138	Maintain deployable cyber defense audit toolkit (e.g., specialized cyber defense software and hardware) to support cyber defense audit missions.
T0142	Maintain knowledge of applicable cyber defense policies, regulations, and compliance documents specifically related to cyber defense auditing.
T0188	Prepare audit reports that identify technical and procedural findings and provide recommended remediation strategies/solutions.
T0252	Conduct required reviews as appropriate within environment (e.g., Technical Surveillance, Countermeasure Reviews [TSCM], TEMPEST countermeasure reviews).
T0549	Perform technical (evaluation of technology) and nontechnical (evaluation of people and operations) risk and vulnerability assessments of relevant technology focus areas (e.g., local computing environment, network and infrastructure, enclave boundary, supporting infrastructure, and applications).
T0550	Make recommendations regarding the selection of cost-effective security controls to mitigate risk (e.g., protection of information, systems and processes).

SSDF Background Material

**Note: This material is extracted from the NIST SSDF documentation.
It is included here for reference only.**

The NIST Secure Software Development Framework (**SSDF**) provides a more general approach which calls out numerous practices and provides references to the applicable standards. SSDF's groups are:

- [Prepare the Organization](#) (PO)
- [Protect Software](#) (PS)
- [Produce Well-Secured Software](#) (PW)
- [Respond to Vulnerability Reports](#) (RV)

Within each of these are multiple practices and tasks.

Prepare the Organization (PO) Practices

Predecessor: N/A

Successor: [Protect Software \(PS\) Practices](#)

Define Security Requirements for Software Development (PO.1)

Ensure security requirements for software development are known at all times so they can be taken into account throughout the SDLC, and duplication of effort can be minimized because the requirements information can be collected once and shared. This includes requirements from internal sources, such as the organization's policies, business objectives, and risk management strategy, and external sources, such as applicable laws and regulations.

Implement Roles and Responsibilities (PO.2)

Ensure everyone inside and outside the organization involved in the SDLC is prepared to perform their SSDF-related roles and responsibilities throughout the SDLC.

Implement a Supporting Toolchain (PO.3)

Use automation to reduce the human effort needed and improve the accuracy, consistency, and comprehensiveness of security practices throughout the SDLC, as well as a way to document and demonstrate use of these practices without significant additional effort or expense.

Define Criteria for Software Security Checks (PO.4)

Help ensure the software resulting from the SDLC meets the organization's expectations by defining criteria for checking the software's security during development.

Note: PO.4 applies to both the foundation and requirements phases

Protect Software (PS) Practices

Predecessor: [Prepare the Organization \(PO\) Practices](#)

Successor: [Produce Well-Secured Software \(PW\) Practices](#)

Protect All Forms of Code from Unauthorized Access and Tampering (PS.1)

Help prevent unauthorized changes to code, both inadvertent and intentional, which could circumvent or negate the intended security characteristics of the software. For code not intended to be publicly accessible, it helps prevent theft of the software and makes it more difficult for attackers to find vulnerabilities in the software.

Note: PS.1 should be in the foundation phase

Provide a Mechanism for Verifying Software Release Integrity (PS.2)

Help software consumers ensure the software they acquire is legitimate and has not been tampered with.

Note: PS.2 should be in the foundation phase

Archive and Protect Each Software Release (PS.3)

Helps identify, analyze, and eliminate vulnerabilities discovered in the software after release.

Note: PS.3 should be in the foundation phase

Produce Well-Secured Software (PW) Practices

Predecessor: [Protect Software \(PS\) Practices](#)

Successor: [Respond to Vulnerability Reports \(RV\) Practices](#)

Take Security Requirements and Risk Information into Account During Software Design (PW.1)

Determine which security requirements the software's design should meet and determine what security risks the software is likely to face during production operation and how those risks should be mitigated by the software's design. Addressing security requirements and risks during software design instead of later helps to make software development more efficient.

Note: PW.1 applies to the design phase

Review the Software Design to Verify Compliance with Security Requirements and Risk Information (PW.2)

Help ensure the software will meet the security requirements and satisfactorily address the identified risk information.

Note: PW.2 applies to the design phase

Verify Third-Party Software Compiles with Security Requirements (PW.3)

Reduce the risk associated with using acquired software modules and services, which are potential sources of additional vulnerabilities.

Note: PW.3 applies to the design phase

Reuse Existing, Well-Secured Software When Feasible Instead of Duplicating Functionality (PW.4)

Lower the costs of software development, expedite software development, and decrease the likelihood of introducing additional security vulnerabilities into the software. These are particularly true for software that implements security functionality, such as cryptographic modules and protocols.

Note: PW.4 applies to the implementation phase

Create Source Code Adhering to Secure Coding Practice (PW.5)

Decrease the number of security vulnerabilities in the software and reduce costs by eliminating vulnerabilities during source code creation.

Note: PW.5 applies to the implementation phase

Configure the Compilation and Build Process to Improve Executable Security (PW.6)

Decrease the number of security vulnerabilities in the software and reduce costs by eliminating vulnerabilities before testing occurs.

Note: PW.6 applies to the implementation phase

Review and/or Analyze Human-Readable Code to Identify Vulnerabilities and Verify Compliance with Security Requirements (PW.7)

Help identify vulnerabilities before software is released so they can be corrected before release, which prevents exploitation. Using automated methods lowers the effort and resources needed to detect vulnerabilities. Human-readable code is source code and any other form of code an organization deems as human readable.

Note: PW.7 applies to the implementation phase

Test Executable Code to Identify Vulnerabilities and Verify Compliance with Security Requirements (PW.8)

Help identify vulnerabilities before software is released so they can be corrected before release, which prevents exploitation. Using automated methods lowers the effort and resources needed to detect vulnerabilities. Executable code is binaries, directly executed bytecode, directly executed source code, and any other form of code an organization deems as executable.

Note: PW.8 applies to the verification phase

Configure the Software to Have Secure Settings by Default (PW.9)

Help improve the security of the software at installation time, which reduces the likelihood of the software being deployed with weak security settings that would put it at greater risk of compromise.

Note: PW.9 applies to the implementation phase

Respond to Vulnerability Reports (RV) Practices

Predecessor: [Produce Well-Secured Software \(PW\) Practices](#)

Successor: N/A

Identify and Confirm Vulnerabilities on an Ongoing Basis (RV.1)

Help ensure vulnerabilities are identified more quickly so they can be remediated more quickly, reducing the window of opportunity for attackers.

Assess and Prioritize the Remediation of all Vulnerabilities (RV.2)

Help ensure vulnerabilities are remediated as quickly as necessary, reducing the window of opportunity for attackers.

Analyze Vulnerabilities to Identify Their Root Causes (RV.3)

Help reduce the frequency of vulnerabilities in the future.

MSSDL Background Material

Note: This material is extracted from the Microsoft SDL documentation.
It is included here for reference only.

The archetype for the SDL is the Microsoft SDL (**MSSDL**). It is visualized as follow:

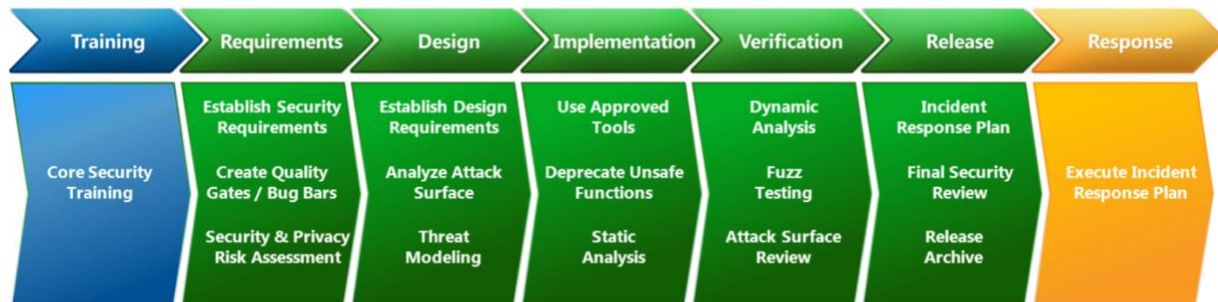


Figure 2: The Microsoft Security Development Lifecycle - Simplified

Figure 1 - MSSDL Lifecycle

The seven phases are:

- Training
- Requirements
- Design
- Implementation
- Verification
- Release
- Response

These are performed in a cyclic fashion where phases 2 through 6 are performed in epicycles (sprints) within the overall cycle (releases).

Reference Documents

1. **NICE Cybersecurity Workforce Framework (NCWF)**
<https://nvlpubs.nist.gov/nistpubs/SpecialPublications/NIST.SP.800-181r1.pdf>
2. **Secure Software Development Framework (SSDF)**
<https://nvlpubs.nist.gov/nistpubs/SpecialPublications/NIST.SP.800-218-draft.pdf>
3. **Microsoft Security Development Lifecycle (SDL) - simplified implementation**
<http://download.microsoft.com/download/F/7/D/F7D6B14F-0149-4FE8-A00F-0B9858404D85/Simplified Implementation of the SDL.doc>